

HOW TO IMPLEMENT ISO/IEC 27001

A Practical Guide to Building, Operating, Auditing, and Improving an ISMS

Alberto (Al) Leiva

Version 1.0 - July 2026

Notice: *This guide is educational and does not replace the official standard, legal advice, or a certification audit.*

How to Use This Guide

- Read the sections in order for a new implementation.
- Use the tables and checklists as starting templates.
- Adapt the ISMS to your context and risks.
- Consult the official standard for complete requirements.

Implementation Map

Clause	Implementation focus	Typical evidence
4 Context	Issues, interested parties, scope, processes	Context register, stakeholder register, scope statement, process map
5 Leadership	Policy, roles, commitment	Approved policy, role descriptions, steering minutes
6 Planning	Risk, treatment, objectives, changes	Methodology, risk register, treatment plan, objectives
7 Support	Resources, competence, awareness, communication, documents	Training records, communication plan, document control
8 Operation	Risk processes and operational controls	Control records, tickets, reports, approvals
9 Performance	Monitoring, internal audit, management review	Metrics, audit reports, review minutes
10 Improvement	Nonconformity, corrective action, continual improvement	Corrective-action records, lessons learned

1. What ISO/IEC 27001 Is

ISO/IEC 27001 is the requirements standard for establishing, implementing, maintaining, and continually improving an information security management system (ISMS). It is risk-based and adaptable to organizations of different sizes and industries.

The standard is not a checklist of technologies. It requires leadership, governance, risk management, objectives, competence, operational control, performance evaluation, and continual improvement.

2. Current Edition and Amendment

Use ISO/IEC 27001:2022 together with ISO/IEC 27001:2022/Amd 1:2024. The amendment requires organizations to determine whether climate change is a relevant issue in the organizational context and recognizes that interested parties may have climate-related requirements.

ISO/IEC 27002:2022 provides implementation guidance for information security controls. It supports control design but is not itself the certification requirements standard.

3. Define the Business Case

Clarify why the organization is implementing an ISMS: customer trust, contractual requirements, regulatory obligations, resilience, risk reduction, market access, or certification.

Define measurable outcomes such as reduced high-risk findings, faster access reviews, improved incident readiness, fewer overdue actions, and stronger audit evidence.

4. Establish Governance and Roles

Executive leadership must approve the ISMS direction, provide resources, assign responsibilities, and review performance.

Create an ISMS steering group with representatives from security, technology, privacy, legal, HR, procurement, facilities, operations, and relevant business units.

5. Understand Organizational Context

Identify internal and external issues that can affect information security objectives. Consider strategy, culture, technology, suppliers, laws, geopolitical conditions, market expectations, physical environment, and relevant climate-related issues.

Identify interested parties and their relevant requirements, including customers, employees, regulators, owners, suppliers, insurers, and business partners.

6. Define the ISMS Scope

Document the organizational units, locations, processes, technologies, information, services, and interfaces included in the ISMS.

Avoid an artificially narrow scope that excludes important dependencies. Record boundaries, exclusions, shared services, supplier interfaces, and reasons for scope decisions.

7. Build the Information Asset and Process Inventory

Inventory critical information, systems, applications, cloud services, facilities, business processes, suppliers, and owners.

Classify assets according to confidentiality, integrity, availability, privacy, legal, and business requirements. Keep the inventory maintainable rather than unnecessarily complex.

8. Design the Risk Assessment Method

Define consistent criteria for likelihood, impact, risk levels, acceptance, reassessment, and escalation.

Assess risks to confidentiality, integrity, and availability. Include people, process, technology, physical, supplier, cloud, privacy, and emerging-technology risks.

9. Perform the Risk Assessment

Identify risk scenarios, affected assets or processes, threats, vulnerabilities, existing controls, likelihood, impact, and risk owners.

Record inherent risk before treatment and residual risk after controls. Document uncertainty and assumptions rather than presenting estimates as exact facts.

10. Create the Risk Treatment Plan

Choose whether to modify, avoid, share, or retain each risk. Assign action owners, resources, deadlines, and expected residual risk.

Risk acceptance must be performed by an authorized risk owner using defined criteria. Security teams should not silently accept business risk on behalf of leadership.

11. Select Controls and Build the Statement of Applicability

Compare selected controls with Annex A and determine which controls are applicable. Controls may also come from legal requirements, contracts, risk treatment, customer obligations, or other frameworks.

The Statement of Applicability should identify each Annex A control, applicability, implementation status, justification for inclusion or exclusion, and supporting references.

Theme	Controls	Examples
Organizational	37	Policies, roles, threat intelligence, suppliers, cloud, incident management, continuity
People	8	Screening, terms, awareness, disciplinary process, remote work, reporting
Physical	14	Perimeters, entry, secure areas, equipment, media, utilities, disposal
Technological	34	Identity, access, malware, vulnerabilities, logging,

		networks, cryptography, development
--	--	-------------------------------------

12. Develop Policies, Standards, and Procedures

Create a concise information security policy supported by topic-specific standards and operational procedures.

Documents should identify purpose, scope, roles, required actions, exceptions, review frequency, approvals, and evidence. Avoid policies that describe controls the organization does not actually perform.

13. Implement People and Supplier Controls

Address screening where lawful, confidentiality, onboarding, role changes, termination, awareness, acceptable use, remote work, disciplinary processes, and reporting responsibilities.

For suppliers, perform due diligence, define security clauses, control access, monitor service performance, manage subcontractors, and plan secure exit or transition.

14. Implement Technical and Physical Controls

Implement controls according to risk, including identity and access management, secure configuration, vulnerability management, encryption, logging, backup, network security, endpoint protection, secure development, cloud security, and incident detection.

Protect offices, data centers, equipment, media, utilities, environmental conditions, secure areas, and disposal processes according to business and risk needs.

15. Operate the ISMS and Retain Evidence

Operate controls consistently and retain reliable evidence such as approvals, tickets, reports, configurations, logs, training records, access reviews, supplier reviews, test results, and meeting minutes.

Evidence should demonstrate both control design and operation over time. Screenshots alone are often weak unless they include context, source, date, owner, and population.

16. Monitor Objectives and Metrics

Define information security objectives that are measurable and aligned with business priorities.

Use meaningful metrics such as overdue risk treatments, access-review completion, backup restoration success, high-risk vulnerabilities, incident response time, supplier-review completion, policy exceptions, and audit findings.

17. Conduct Internal Audits

Create a risk-based audit program covering the ISMS requirements and selected controls over a planned cycle.

Internal auditors should be competent and sufficiently independent from the activities they audit. Record criteria, scope, methods, evidence, findings, and follow-up.

Minimum Audit Program

- Clauses 4 through 10
- Selected controls and Statement of Applicability
- High-risk processes
- Previous corrective actions
- Significant changes

18. Perform Management Review

Top management should periodically review ISMS performance, changes in context, interested-party needs, objectives, audit results, incidents, risks, opportunities, resources, and improvement actions.

Management review must result in documented decisions and actions, not only a presentation.

19. Correct Nonconformities and Improve

When a requirement is not met, contain the issue, correct it, analyze root causes, determine whether similar issues exist, implement corrective action, and verify effectiveness.

Continual improvement should be driven by audits, incidents, monitoring, risk changes, employee feedback, supplier performance, technology changes, and lessons learned.

20. Certification Readiness

Certification is optional and performed by an accredited certification body. Stage 1 generally reviews readiness and documented arrangements; Stage 2 evaluates implementation and effectiveness.

Before certification, complete an internal audit, management review, corrective actions, evidence review, and readiness assessment. Do not claim certification until a valid certificate has been issued.

Period	Priorities
Days 1-30	Business case, governance, context, scope, inventory, gap assessment
Days 31-60	Risk method, risk assessment, treatment, Statement of Applicability, core documents
Days 61-90	Control operation, evidence, metrics, internal audit preparation, corrective actions

Practical Checklists and Templates

Readiness Checklist

- ☐ Executive sponsor and ISMS manager assigned
- ☐ Context and interested parties documented
- ☐ Climate relevance considered
- ☐ ISMS scope approved
- ☐ Asset and process inventory established
- ☐ Risk methodology approved
- ☐ Risk assessment completed
- ☐ Risk treatment plan approved
- ☐ Statement of Applicability completed
- ☐ Policies and procedures approved
- ☐ Competence and awareness records available
- ☐ Supplier controls operating
- ☐ Technical and physical controls operating
- ☐ Objectives and metrics monitored
- ☐ Internal audit completed
- ☐ Management review completed
- ☐ Nonconformities and corrective actions addressed
- ☐ Certification claims reviewed for accuracy

Sample risk register fields

- Risk ID
- Business process or asset
- Risk scenario
- Threat and vulnerability
- Existing controls
- Likelihood
- Impact
- Inherent risk
- Treatment action
- Owner
- Due date
- Residual risk
- Acceptance decision
- Review date

Sample Statement of Applicability fields

- Annex A control
- Applicable?
- Justification
- Implementation status
- Control owner
- Policy or procedure reference
- Evidence location
- Last review date

Sample internal audit record

- Audit objective and scope
- Criteria
- Auditor
- Dates
- Methods
- Evidence sampled
- Conformities
- Nonconformities
- Observations
- Corrective-action owner
- Due date
- Follow-up result

Common Mistakes

- Buying templates and treating them as a finished ISMS.
- Creating too many documents that nobody uses.
- Narrowing scope to hide critical dependencies.
- Confusing a policy with evidence of operation.
- Accepting risk without proper authority.
- Preparing for audit only a few weeks before it begins.
- Claiming certification before a valid certificate is issued.

Official References

[ISO/IEC 27001:2022 official page](#)

[ISO/IEC 27001:2022/Amd 1:2024](#)

[ISO/IEC 27002:2022 official page](#)

[ISO/IEC 27000 family](#)

License

Copyright © 2026 Alberto (Al) Leiva. Licensed under CC BY-NC-SA 4.0.